VibeScan: Multi-Dimensional Benchmark Analysis for JavaScript Security Scanning

A reproducible multi-dimensional study on adjudicated DVNA with aligned peer tool runs: recall, cases-per-alert precision proxy, per-family coverage, and wall-clock scan time. CCSC 2026.

AUTHORS: JOSH OBERSTEADT, ANDREW YOUSSEF

Mentors: Kevin Brunner | Aquilla Galusha

Research Questions

CROSS-TOOL DVNA RESULTS

Tools: 1 VibeScan 2 Bearer 3 Snyk Code 4 Semgrep 5 CodeQL 6 ESLint

FIGURE 3 — COVERAGE BY VULNERABILITY CATEGORY (DVNA CORE)

VibeScan is the only tool with full coverage across all vulnerability categories, especially outperforming in complex injection and client-side cases.

Category · Scenarios covered		1 · VibeScan	2 · Bearer	3 · Snyk	4 · Semgrep	5 · CodeQL	6 · ESLint
Injection	SQL, Command, NoSQL (3)	100%	100%	66%	33%	66%	33%
Redirect & Nav	Open Redirect (1)	100%	100%	100%	100%	100%	0%
Integrity	Unsafe Deserialization (1)	100%	0%	100%	100%	100%	0%
Secrets & Crypto	Secrets + Weak Hash (2)	100%	100%	100%	50%	50%	0%
Auth & Client	Env + XSS (2)	100%	0%	50%	0%	50%	0%
Overall recall (11 cases)		100%	72.7%	63.6%	36.4%	54.5%	9.1%

The matrix groups DVNA's 11 benchmark cases into five vulnerability categories. VibeScan is the only scanner to achieve 100% coverage across all five. Peer tools perform well on Injection and Redirect but drop sharply in Auth & Client-side, where only VibeScan detects both cases — highlighting the coverage gap that raw alert counts obscure.

FIGURE 2 — RECALL VS. RAW ALERT VOLUME

Corpus by vulnerability class: the 11 hand-adjudicated cases. Peer rules are VibeScan's continues.

Noisy static analysis can sell a false sense of security. A single plugin that catches everything, including dev-only files and test fixtures, can look like a high-recall tool on paper. The metric that matters is how much of what it reports is actually worth acting on. Raw alert counts are a proxy for attention cost, not for correctness. Cases-per-alert is a rough proxy for signal density, but it still requires ground truth to be meaningful. Vibe Scan's 100% recall on 11 cases is a claim about coverage on a curated benchmark, not about production performance. Real-world validation is the next step.

FIGURE 4 — OVERALL PERFORMANCE RANKING

Ranked dot plot of DVNA recall. Higher and farther right is better.

This ranked dot plot makes ordering immediate: VibeScan leads with full recall, followed by Bearer and Snyk Code at mid-tier coverage, while CodeQL and Semgrep trail on missed cases. The compact format preserves exact values while reducing clutter versus a second scatter chart.

FIGURE 5 — EFFICIENCY QUADRANT (SPEED VS. RECALL)

Quadrants split by median speed and median recall; top-right is fastest with higher recall.

Quadrant interpretation of the same scan-time and recall data. Top-right indicates the best efficiency balance.

The quadrant framing adds immediate interpretation: VibeScan sits nearest the ideal region by combining very high recall with fast execution. Bearer and Snyk Code retain moderate recall but at slower runtime, while Semgrep and ESLint drop into lower-efficiency regions. CodeQL trends right on speed but remains mid-recall, reinforcing that runtime alone does not imply better detection.

Key Findings & Limits

- **Best overall:** VibeScan detects all DVNA cases (11/11) and is the fastest scan (0.86 s).
- **Where peers miss:** Injection/Secrets are often covered, but Auth/XSS are detected by ≤ 2 tools.
- **Hard-case gap:** Every high-difficulty case (Δ ≥ 14) is missed by 4+ peer tools.
- **How to read precision:** Cases-per-alert is a proxy, not full adjudicated precision.
- **Scope note:** Expanded corpus coverage remains VibeScan-focused.

References

1. [1] AppSecCo. *Damn Vulnerable Node Application (DVNA)*. github.com/appsecco/dvna.
2. [2] OWASP Foundation. *OWASP Top 10:2021*. owasp.org/Top10/.
3. [3] Semgrep, Inc. *Semgrep documentation*. semgrep.dev/docs.
4. [4] GitHub. *CodeQL documentation*. codeql.github.com/docs.
5. [5] ESLint Community. *eslint-plugin-security*. github.com/eslint-community/eslint-plugin-security.
6. [6] Snyk Ltd. *Snyk CLI*. docs.snyk.io/snyk-cli.
7. [7] Bearer. *Bearer (open-source SAST)*. github.com/Bearer/bearer.
8. [8] ETS. *Final Study Statistical Analysis for the Redesigned TOEIC Bridge Tests (RM-19-09)*, item difficulty definitions for p and delta.